Strict-Transport-Security

The HTTP **`Strict-Transport-Security`** response header (often abbreviated as HSTS) informs browsers that the site should only be accessed using HTTPS, and that any future attempts to access it using HTTP should automatically be converted to HTTPS.

Note: This is more secure than simply configuring a HTTP to HTTPS (301) redirect on your server, where the initial HTTP connection is still vulnerable to a man-in-the-middle attack.

Header type	Response header
Forbidden header name	no

Syntax

```
Strict-Transport-Security: max-age=<expire-time>
Strict-Transport-Security: max-age=<expire-time>; includeSubDomains
Strict-Transport-Security: max-age=<expire-time>; includeSubDomains; preload
```

Directives

`max-age=<expire-time>`

The time, in seconds, that the browser should remember that a site is only to be accessed using HTTPS.

`includeSubDomains Optional`

If this optional parameter is specified, this rule applies to all of the site's subdomains as well.

`preload Optional Non-standard`

See Preloading Strict Transport Security for details. When using `preload`, the `max-age` directive must be at least `31536000` (1 year), and the `includeSubDomains` directive must be present. Not part of the specification.

Description

If a website accepts a connection through HTTP and redirects to HTTPS, visitors may initially communicate with the non-encrypted version of the site before being redirected, if, for example, the visitor types `http://www.foo.com/` or even just foo.com. This creates an opportunity for a man-in-the-middle attack. The redirect could be exploited to direct visitors to a malicious site instead of the secure version of the original site.

The HTTP Strict Transport Security header informs the browser that it should never load a site using HTTP and should automatically convert all attempts to access the site using HTTP to HTTPS requests instead.

Note: The `Strict-Transport-Security` header is *ignored* by the browser when your site has only been accessed using HTTP. Once your site is accessed over HTTPS with no certificate errors, the browser knows your site is HTTPS capable and will honor the `Strict-Transport-Security` header. Browsers do this as attackers may intercept HTTP connections to the site and inject or remove the header.

An example scenario

You log into a free Wi-Fi access point at an airport and start surfing the web, visiting your online banking service to check your balance and pay a couple of bills. Unfortunately, the access point you're using is actually a hacker's laptop, and they're intercepting your original HTTP request and redirecting you to a clone of your bank's site instead of the real thing. Now your private data is exposed to the hacker. Strict Transport Security resolves this problem; as long as you've accessed your bank's website once using HTTPS, and the bank's website uses Strict Transport Security, your browser will know to automatically use only HTTPS, which prevents hackers from performing this sort of man-in-the-middle attack.

How the browser handles it

The first time your site is accessed using HTTPS and it returns the `Strict-Transport-Security` header, the browser records this information, so that future attempts to load the site using HTTP will automatically use HTTPS instead.

When the expiration time specified by the `Strict-Transport-Security` header elapses, the next attempt to load the site via HTTP will proceed as normal instead of automatically using HTTPS.
Whenever the `Strict-Transport-Security` header is delivered to the browser, it will update the expiration time for that site, so sites can refresh this information and prevent the timeout from

expiring. Should it be necessary to disable `Strict Transport Security`, setting the `max-age` to 0 (over an https connection) will immediately expire `the Strict-Transport-Security` header, allowing access via http.

Preloading Strict Transport Security

Google maintains an HSTS preload service. By following the guidelines and successfully submitting your domain, you can ensure that browsers will connect to your domain only via secure connections. While the service is hosted by Google, all browsers are using this preload list. However, it is not part of the HSTS specification and should not be treated as official.

- Information regarding the HSTS preload list in Chrome: https://www.chromium.org/hsts
- Consultation of the Firefox HSTS preload list: nsSTSPreloadList.inc

Examples

All present and future subdomains will be HTTPS for a `max-age` of 1 year. This blocks access to pages or subdomains that can only be served over HTTP.

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

Although a `max-age` of 1 year is acceptable for a domain, two years is the recommended value as explained on https://hstspreload.org.

In the following example, max-age is set to 2 years, and is suffixed with preload, which is necessary for inclusion in all major web browsers' HSTS preload lists, like Chromium, Edge, and Firefox.

```
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
```

Specifications

HTTP Strict Transport Security (HSTS) # section-6.1

This lesson is adapted from MDN web Docs: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security